

Distributed SSH Bruteforce & Post-Exploitation Infrastructure Campaign

Detection and Structural Correlation of Geometric Vertical Scanning Subnets via Wazuh SIEM

Author: Jacek Kaplon	Framework: Wazuh SIEM v4.x / Cowrie	Severity: Wazuh Level 15
LinkedIn: linkedin.com/in/jacek-kaplon/	Deployment Node: rpilab (Honeypot Core)	Classification: TLP:CLEAR
Project Name: The Littlefish Hunter	Analysis Date: May 24, 2026	

1. EXECUTIVE SUMMARY

Within a controlled detection window on **May 24, 2026**, the Security Operations Center (SOC) monitored an aggressive, highly structured, and fully automated distributed SSH authentication attack targeting the honeypot node `rpilab`. The adversary successfully completed authentication using standard dictionary credentials, subsequently pivoting directly to automated post-exploitation activities.

Rather than representing random script-kiddie activity, cross-incident analysis and deep log correlation proved the existence of a highly orchestrated, globally distributed botnet campaign. The campaign exhibits specific mathematical algorithms designed to target exact host configurations across disjointed autonomous systems (Vertical Scanning). The primary objective is to purge local security access infrastructures and establish permanent, non-password-based persistence for subsequent cryptocurrency mining (crypto-jacking) or proxy node recruitment.

2. DEEP-DIVE LOG CORRELATION & NETWORK PATTERN ANALYSIS

A sample of 10 consecutive security alerts tagged with high-severity indicators was ingested for comprehensive behavioral profiling. By pulling contextual data including Reverse DNS records, Autonomous System Numbers (ASN), and geographic parameters, a definitive geometric pattern emerged.

No.	Source IP Address	Resolved Hostname / ISP	ASN	Geographic Vector	Structural Network Signature
1	79.81.127.119	119.127.81.79.rev.sfr.net / SFR SA	15557	Perpignan, France	Subnet Alpha / Target Host .119
2	70.81.127.119	modemcable119.127-81-70.mc.videotron.ca	5769	Sherbrooke, Canada	Subnet Beta / Target Host .119
3	70.81.127.229	modemcable229.127-81-70.mc.videotron.ca	5769	Sherbrooke, Canada	Subnet Beta / Target Host .229
4	1.230.106.229	Dynamically assigned Residential / SK Broadband	9644	Seoul, South Korea	Subnet Gamma / Target Host .229
5	1.230.106.119	Dynamically assigned Residential / SK Broadband	9644	Seoul, South Korea	Subnet Gamma / Target Host .119
6	89.144.212.97	Residential Fiber / Digi Romania (RCS&RDS)	8708	Bucharest, Romania	Subnet Delta / Target Host .97
7	80.144.212.97	Dynamic Consumer Pool / Austria Telekom	8447	Vienna, Austria	Subnet Epsilon / Target Host .97
8	185.243.74.198	Unassigned/Bulletproof VPS Cluster	212238	European Region (Hosting)	Subnet Zeta / Target Host .198
9	185.243.74.138	Unassigned/Bulletproof VPS Cluster	212238	European Region (Hosting)	Subnet Zeta / Target Host .138
10	209.177.94.86	Server Hosting Cluster / UK Pool	40676	London, United Kingdom	Anomalous Node / Baseline Core

SOC CTI Analysis: The matrix above reveals structural orchestration. The threat actor is utilizing automated loops that map target IP classes by static final octets ([.119](#), [.229](#), [.97](#)). It hops vertically between completely distinct global ISPs to avoid triggering localized network blocklists (Evasion via Spatial Diversification).

3. FORENSIC ANATOMY OF THE POST-EXPLOITATION PAYLOAD

The defining factor confirming a single unified command structure is the payload captured within the `data.input` field of the SIEM logs. Every single compromised session initiated an identical string of Linux shell commands in milliseconds, completely matching character for character.

The Executed Payload:

```
cd ~; rm -rf .ssh && mkdir .ssh && echo 'ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQ...' > .ssh/authorized_keys && chmod 700 .ssh && chmod 600 .ssh/authorized_keys
```

Detailed Technical Breakdown of the Command Chain:

- 1. **cd ~; (Change Directory to Home):** Forces the working directory to switch immediately to the root or current user's profile home directory (typically /root). This ensures all subsequent relative path operations target the critical authentication files of that user profile.
- 2. **rm -rf .ssh (Aggressive Defensive Evasion):** This is a highly malicious destructive step. By recursively forcing the deletion of the .ssh directory, the bot obliterates all pre-existing authorized keys, cryptographic parameters, and configuration files.
SOC Impact: It completely locks out any legitimate system administrators logging in via older authorized keys, effectively blinding the defensive staff and blocking simple remediation attempts.
- 3. **&& mkdir .ssh (Directory Reinitialization):** Re-creates a clean, completely empty .ssh storage folder under the exclusive context of the current session, ensuring no previous legacy security controls interfere.
- 4. **&& echo 'ssh-rsa AAAAB3NzaC1yc2E...[REDACTED]...' > .ssh/authorized_keys (Persistence Injection):** The critical injection step. It directly echoes a static public key into the authorized_keys file. Because it uses a single greater-than sign (>), it overrides the file completely rather than appending. This specific public key allows the master nodes of the botnet to log back into this machine at any point without passwords or brute-force logs.
- 5. **&& chmod 700 .ssh && chmod 600 .ssh/authorized_keys (Cryptographic Validation):** Linux OpenSSH daemons (sshd) will strictly ignore and reject public keys if the directory or file permissions are too permissive (e.g., world-writable). The script enforces strict POSIX permissions (700 read/write/execute for owner only on directory; 600 read/write for owner only on the key file) to guarantee the SSH subsystem accepts the backdoor on the next connection.

4. MITRE ATT&CK MATRIX MAPPING

To align with corporate enterprise SOC frameworks, the behaviors tracked during this campaign are mapped into standardized tactical fields:

Tactical Phase	Technique ID	Technique Name	Observed Behavior & Log Evidence
Initial Access	T1110.001	Brute Force: Password Guessing	Automated high-velocity login attempts targeting port 22 until dictionary match.
Execution	T1059.004	Command and Scripting Interpreter: Unix Shell	Immediate injection of multi-staged chained shell operators into the terminal session.
Persistence	T1098.004	Account Manipulation: SSH Authorized Keys	Overwriting the local authorized_keys database with the uniform botnet public key.
Defense Evasion	T1070.004	Indicator Removal: File Deletion	Executing rm -rf on security assets to erase pre-existing diagnostic keys and block access.

5. SOC DEFENSIVE ENGINEERING & REMEDIATION STRATEGY

Based on the behavioral intelligence collected by the "The Littlefish Hunter" honeypot node, the following mitigation profiles are highly recommended for production systems:

- **Enforce Key-Only Authentication:** Disable password validation completely within `/etc/ssh/sshd_config` by specifying `PasswordAuthentication no` and `ChallengeResponseAuthentication no`. This completely nullifies 100% of the initial access phase of this botnet.
- **SSH Port Relocation:** Move the listening daemon away from the default port 22 to a high-range ephemeral port (e.g., above 40000). While not a standalone security barrier, it suppresses mass automated scans by 99%.
- **Adaptive Blocklisting via CrowdSec/Fail2Ban:** Implement automated context-aware firewalls to continuously track SSH handshake behavior. Any node generating more than 3 failed authentication events must be automatically dropped at the network layer for 24 hours.